

Broken Object Property Level Authorization (BOPLA):

Broken Object Property Level Authorization is an API3:2023 OWASP vulnerability occur when API fails to validate the user should have to access the specific object property not just an object itself.

In 2023, OWASP merged two 2019 vulnerabilities into one :

1) API3:2019 — Excessive Data Exposure :

This type of vulnerability occur when API endpoint exposed the sensitive object property which should not be read by user.

2) API6:2019 — Mass Assignment :

This type of vulnerability occur when user should access to specific object property and able to change/add or delete the specific value of an object property.

Mass Assignment Vulnerability :

Title : Mass assignment in Order API (GET /workshop/api/shop/order/{order_id}) allows refund without returning items

Description : The order endpoint GET /workshop/api/shop/order/{order_id} binds the client supplied JSON body directly to internal object property. This allows an authenticated user to add status property which should only be set server-side and triggering refund without shipping the item.

Attack Scenario :

1) Register a account and logged in into the account :

crAPI

DashboardShopCommunity

Good Morning, victim!

victim

Vehicles Details

VIN: JNGYP6S18U4C88K66

Vehicle Service HistoryContact Mechanic

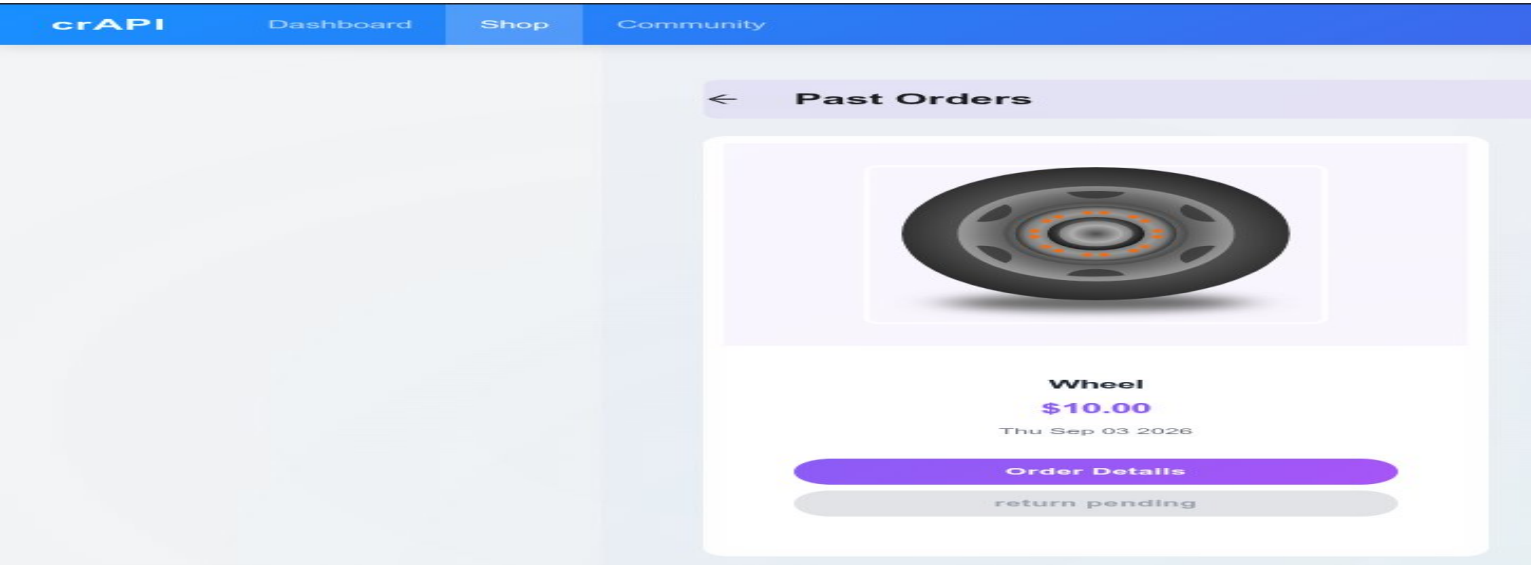
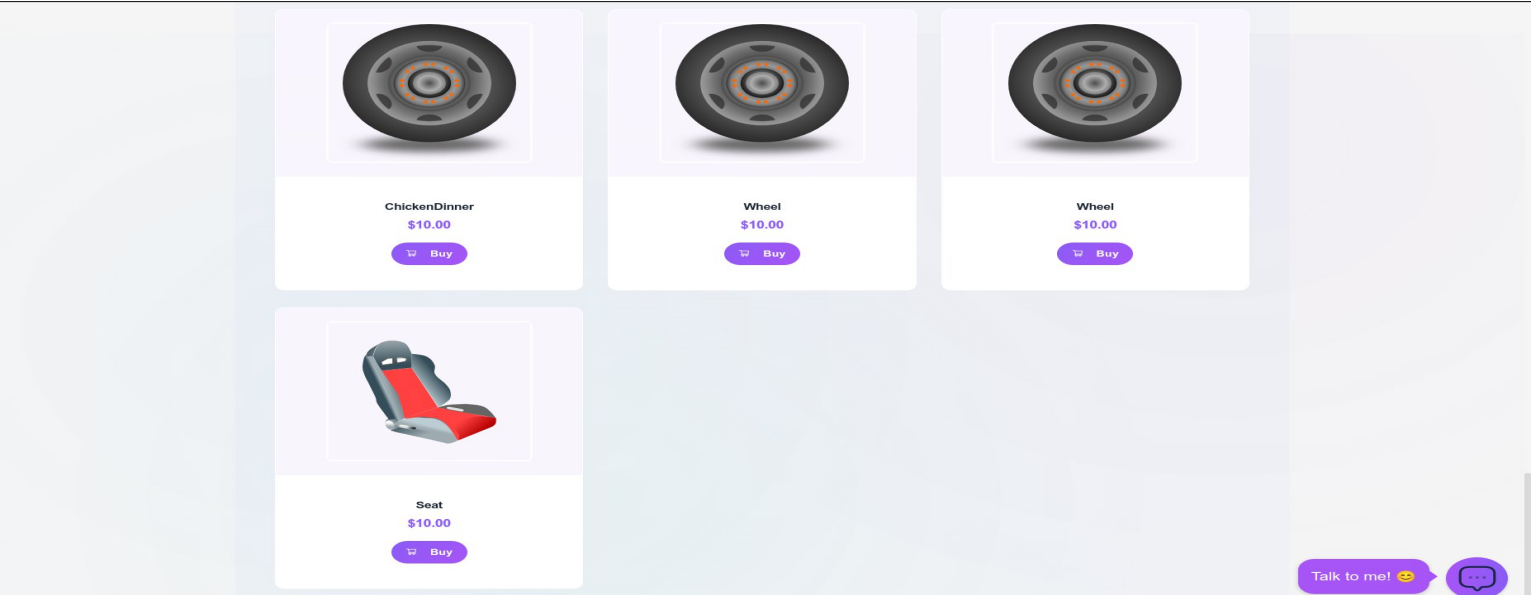
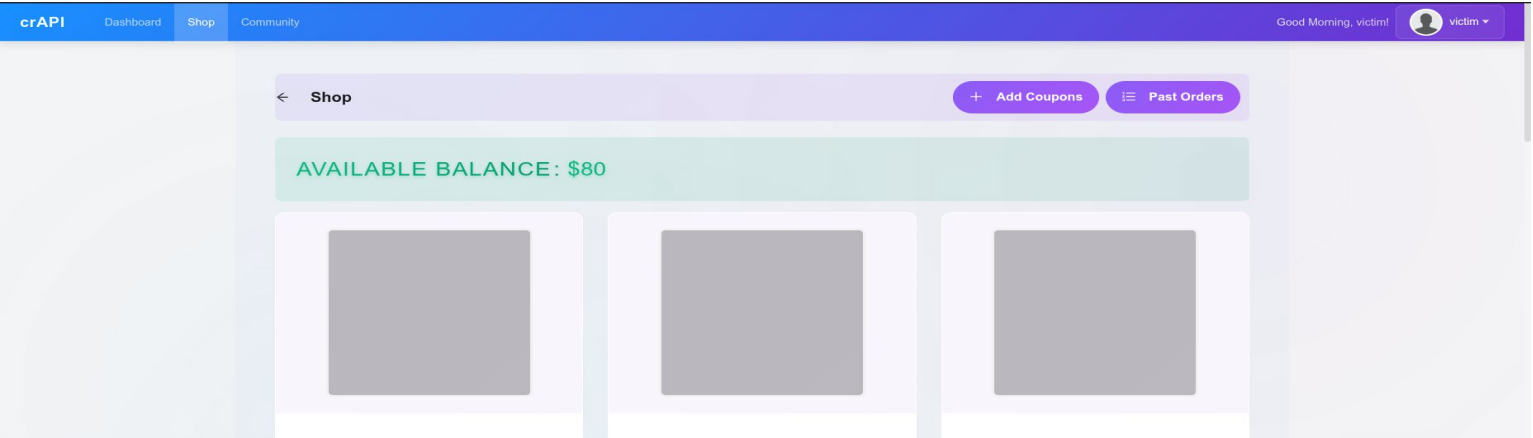


COMPANY :	BMW
MODEL :	5 Series
FUEL TYPE :	PETROL
YEAR :	2026

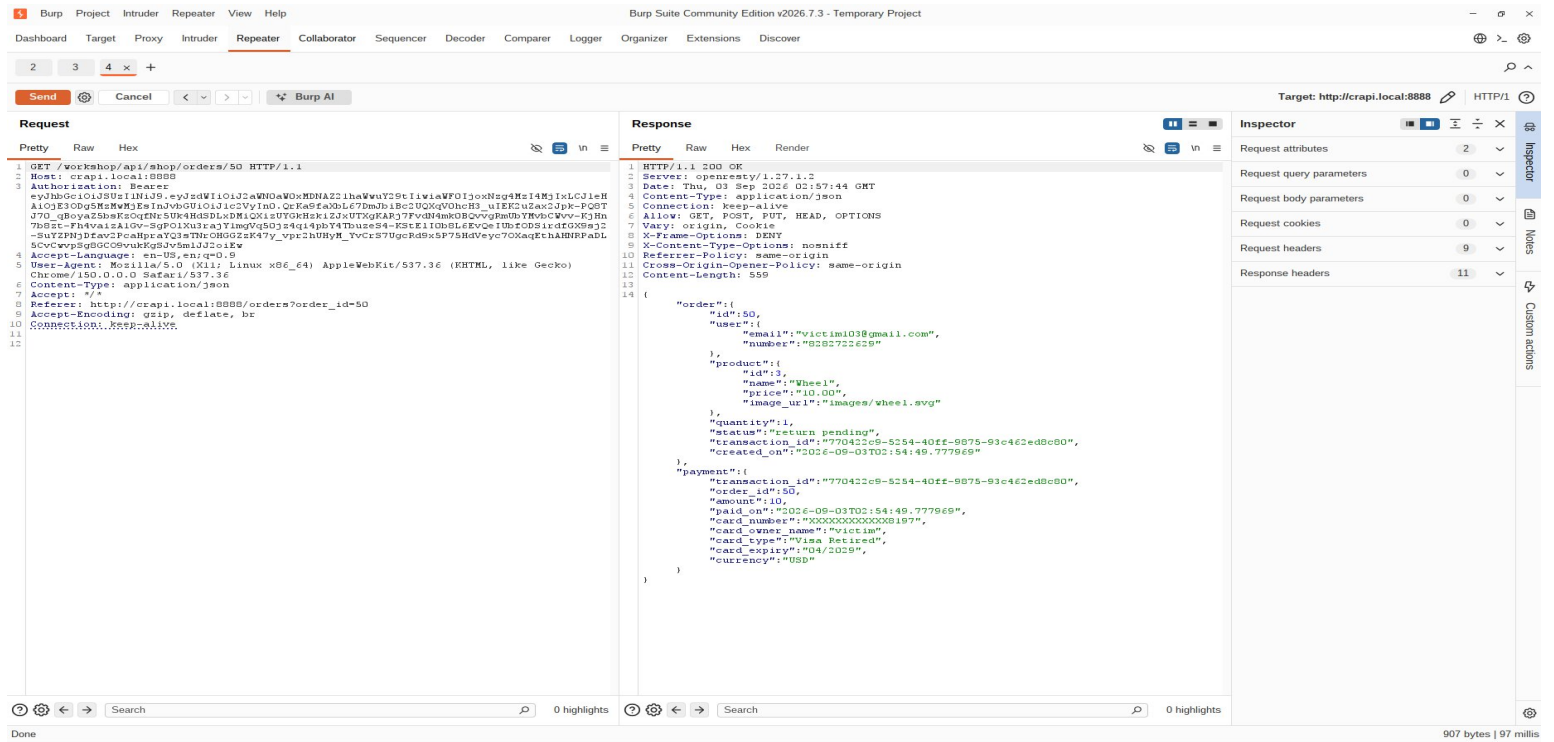


Refresh Location

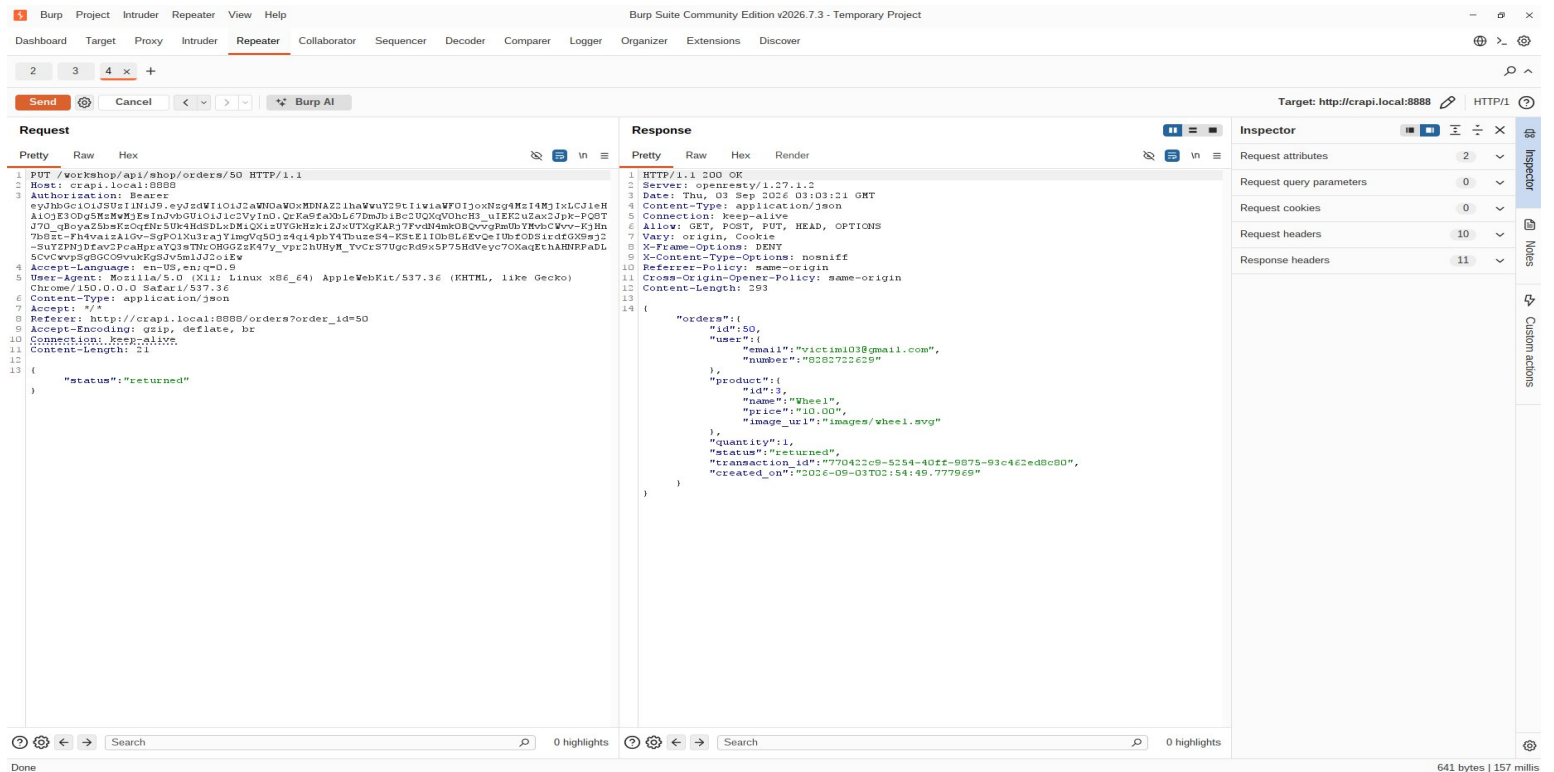
2) Go to shop tab and buy a product and returned it :



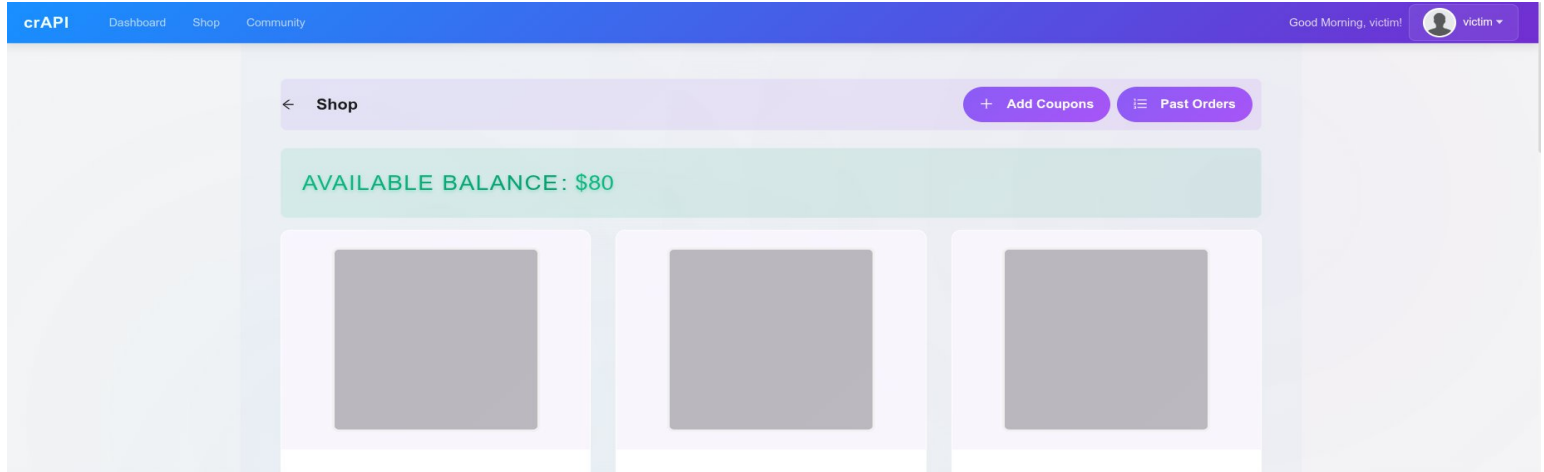
3) Click on Order Details and capture request and send it to repeater:



4) Add JSON property "status": "returned" and change the http method GET —> PUT and send it :



5) We successfully refund by adding JSON property :



Impact :

- Financial fraud: Any authenticated user can trigger refunds for items they keep, directly converting to monetary loss.
- State integrity: Order lifecycle (pending → returned → refunded) is fully client-controlled, bypassing the physical return verification the business relies on.

Remediation :

- Server-side state control: status transitions must be computed server-side through an explicit state machine tied to verified business events (return received → status updated), never accepted from client input.
- Restrict HTTP methods: The object path exposes POST/PUT/DELETE via OPTIONS where only GET is intended — disable unused methods.
- Response schema validation: Enforce an output schema so internal properties don't leak (defense in depth for the read side of BOPLA).

Reference: [OWASP API3:2023 – Broken Object Property Level Authorization](#)

